情報処理安全確保支援士試験　科目A-2　中分類26 セキュリティ実装技術・評価　#19

フォレンジックとセキュリティ評価

消える順に証拠を守る、共通の物差しで脆弱性と製品を測る

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案、RFC 3227、NIST SP 800-86、ISO/IEC 15408、FIPS 140-3、FIRST CVSS・EPSS、MITRE CVE・CWE、NIST SCAP、CRYPTREC など）を書いた。過去問は IPA 公開の午前 II 。例の場面は Claude が作った

全体像 シラバス案 中分類26 小分類2 フォレンジック・小分類3 セキュリティ評価

1 デジタルフォレンジック
揮発性の順序・ディスクイメージと書込み防止・ハッシュ値・Chain of Custody・タイムライン・メモリ

2 マルウェア解析
サンドボックス・ハニーポット・逆アセンブル・アンパック、パッカー・難読化・アンチデバッグ

3 脆弱性の評価
CVE・CWE・CVSS・EPSS・KEV・SSVC・SCAP・SBOM・JVN・ペネトレーションテスト

4 製品と暗号の評価
ISO/IEC 15408・PP・EAL・JISEC、FIPS 140-3・JCMVP・CRYPTREC 暗号リスト

過去の午前 II での出方（16回出題）

テーマ	出た回
揮発性の順序	R3秋・R5春・R7春
CRYPTREC 暗号リスト	H31・R1秋・R5春・R7秋
CVSS・CVE・CWE・SCAP	R1秋・R3春・R5秋・R6春
SBOM・15408・FIPS 140-3	R4秋・R6春
フォレンジック・IoT のペネトレ	R2・R5春

出典：IPA「支援士試験 シラバス（案）Ver.0.1」中分類26 小分類2・3／IPA 午前 II 各回（このPDFの問題演習を参照）

第1章

デジタルフォレンジック

消えやすい順に、変えずに、記録を残して。

揮発性の順序

レジスタ・キャッシュ
最も消えやすい

ルーティングテーブル・ARP キャッシュ・プロセス表・メモリ

一時ファイル

ディスク

遠隔のログ・監視データ

物理的な構成・保管用の媒体
最も残りやすい

R3秋 問12 の答え（エ）

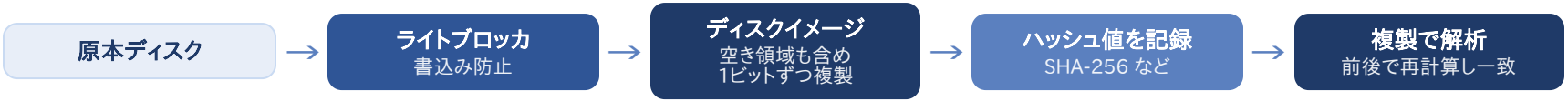
d ルーティングテーブル → **c** ディスクの表計算ファイル → **a** 遠隔のログサーバ → **b** インストール用 CD

R5春・R7春：ARP キャッシュの次は**ルーティングテーブル**（同じメモリ上の情報）。

遠隔のログサーバは PC の電源を切っても消えないので後でよい。

出典：RFC 3227 2.1 Order of Volatility／IPA 令和3年度秋期 午前 II 問12・令和7年度春期 問15

証拠を変えずに守る



手段	示せること
ハッシュ値	中身が1ビットも変わっていない（同一性）
Chain of Custody	いつ・誰が取得し、誰に渡し、どう保管・分析したか（証拠保全の連鎖）
タイムライン分析	作成・更新・アクセスの日時やログを並べ、攻撃者の行動を再構成
メモリフォレンジック	動いていたプロセス・通信・メモリだけにあるマルウェア

> 原本に直接触る・ファイル単位でコピーする・すぐ電源を切る、は証拠を損なう。

出典：NIST SP 800-86 3 Performing the Forensic Process／RFC 3227 4 Archiving Procedure

第2章

マルウェア解析

動かして見る、読んで見る、隠す技術を外す。

解析の環境と手法

仕組み	目的
サンドボックス	隔離した環境で検体を動かし振る舞いを観察（動的）
ハニーポット	わざと攻撃させるおとり。手口を集める
ハニーネット	ハニーポットをつないだおとりのネットワーク
パケットキャプチャ	C&C との通信を記録・分析
逆アセンブル	機械語をアセンブリ言語に戻して読む（静的）

解析を妨げる技術

パッカー
圧縮・暗号化して実行時に自分で展開。パターンで検知されにくい → アンパックして解析

難読化
名前を無意味に、処理を複雑に、文字列を暗号化

アンチデバッグ
デバッガ・仮想環境を検知して止まる・動きを変える

対策ソフトの停止・スリープ
検知を外す、サンドボックスの観察時間をやり過ごす

出典：IPA「支援士試験 シラバス（案）」用語例〔マルウェア解析〕

第3章

脆弱性の評価

名前を付け、種類で分け、深刻さと悪用されやすさを測る。

脆弱性の共通の物差し

名前	何か	例・管理
CVE	個々の脆弱性の識別子（R3春）	CVE-2021-44228／MITRE
CWE	脆弱性の**種類**の一覧（R6春）	CWE-79 XSS／MITRE
CPE	製品を識別するプラットフォーム名の一覧	NIST
CCE	セキュリティ設定項目の識別子	NIST
CVSS	深刻度 0.0〜10.0（R1秋）	FIRST
SCAP	上をまとめて脆弱性管理を自動化（R5秋）	NIST

CWE の問題では、CPE・CCE・CVSS の説明が誤りの選択肢に並ぶ。

出典：MITRE「CVE」「CWE」／NIST「SCAP」／IPA 午前 II R1秋 問9・R3春 問8・R5秋 問12・R6春 問9

CVSS と優先順位付け

版	評価基準
v3.1	**基本・現状・環境**（三つ）
v4.0	基本・脅威・環境・補足

基本
脆弱性そのもの。時間で変わらない

現状（脅威）
攻撃コードの有無など。時間で変わる

環境
利用者の環境に合わせて利用者が評価

深刻さだけでなく悪用の状況も見る

名前	答える問い
CVSS	どれだけ深刻か
EPSS	30日以内に悪用される確率は
KEV	実際に悪用されたか
SSVC	決定木で、どう対応するか

> #12 の脆弱性管理と合わせて使う。

出典：FIRST「CVSS v3.1 Specification」「CVSS v4.0 Specification」「EPSS」／CISA「KEV Catalog」「SSVC」

SBOM・JVN・検査

SBOM（ソフトウェアの部品表、R6春）

```
製品 A 2.3
 ├ ライブラリ X 1.4.2（Apache-2.0）
 │  └ ライブラリ Y 2.0.1
 └ ライブラリ Z 3.1.0（MIT）
```

Y に脆弱性 → SBOM を検索すれば A が影響を受けるとすぐ分かる。形式は SPDX・CycloneDX、作る検査は SCA。

JVN

JPCERT/CC と IPA の脆弱性対策情報ポータル
CVE・CVSS・CWE を採用。データベースは JVN iPedia

検査	何をするか
脆弱性診断	脆弱性を網羅的に洗い出す
ペネトレーションテスト	実際に攻撃・侵入を試みる。IoT はネットワーク・バス・デバッグ IF（R5春）
バグバウンティ	見つけた外部の研究者に報奨金

R5春の誤り：仕様どおりかのテスト＝システムテスト、内部構造を見る＝ホワイトボックス、温湿度＝環境試験。

出典：経済産業省「ソフトウェア管理に向けた SBOM の導入に関する手引」／JVN「JVN について」／IPA 午前 II R5春 問22・R6春 問17

第4章

製品と暗号の評価・認証

第三者が同じ方法で評価するから、比べられる。

ISO/IEC 15408（コモンクライテリア）

PP
製品の種類ごとの要件
（調達者側）

→

ST
個々の製品の対象と要件
（開発者が書く）

→

評価機関
ISO/IEC 18045（CEM）
の方法で評価

→

認証機関
日本は IPA の JISEC
CCRA で相互承認

EAL	1	2	3	4	5	6	7
保証の深さ	浅い →→→→→ 深い（設計の文書や検査をどこまで確かめたか）						

R4秋：「調達者が判断する際に役立つ評価結果を提供し、評価結果間の比較を可能に」→ **15408**。27002＝管理策、27017＝クラウドの管理策、30147＝IoTの信頼性。

EAL は機能の多さ・強さではない。

出典：JIS X 5070（ISO/IEC 15408）／IPA「IT セキュリティ評価及び認証制度（JISEC）」／IPA 令和4年度秋期 午前 II 問9

暗号モジュールと CRYPTREC 暗号リスト

暗号モジュールの評価

FIPS 140-3	NIST の暗号モジュールのセキュリティ要求事項。レベル1〜4（R6春）
ISO/IEC 19790	同じ内容の国際規格
JCMVP	日本の試験・認証制度（IPA）

CRYPTREC 暗号リスト（4回出題）

電子政府推奨暗号リスト
安全性・実装性能を確認、利用実績が十分か普及見込み → 利用を推奨

推奨候補暗号リスト
安全性・実装性能は確認。今後推奨リストに載る可能性

運用監視暗号リスト
解読リスクが高まった。互換性維持のためだけに利用

> 「証明書失効リスト」はこのリストにない（PKI の CRL）。

出典：NIST FIPS 140-3／IPA「JCMVP」／CRYPTREC「電子政府における調達のために参照すべき暗号のリスト」／IPA 午前 II R1秋 問8・R7秋 問1